TradeCheck AI: Governance and Responsible AI (v1.2)

Oct 27, 2026 · @Pratik Hirpara

Summary

TradeCheck AI is a decision support tool: it reads shipment documents, flags inconsistencies and suggests HS codes, but a licensed customs broker makes every decision and nothing is submitted automatically.

- **EU AI Act:** most likely not high risk. Customs document checking for businesses is not one of the eight Annex III areas, and the system only prepares drafts for a human. Every report states that it was generated by AI.
- **GDPR:** the prototype uses only synthetic test data. Real shipment documents contain business contact data, so real use needs a paid AI tier, data processing agreements and a retention rule.
- **Biggest data decision:** the prototype runs on the Google Gemini **free** tier, where Google may use submitted content to improve its products. That is acceptable for synthetic data only.
- **Safety by design:** any doubt forces human review: document inconsistencies, unreadable documents, AI service errors, possible prompt injection, unknown or low confidence codes, and restricted goods. When the classifier is unsure, the report shows no code at all.
- **Tested, not only designed:** each safeguard was tested with at least one failure case in a 28 set evaluation.

This document is a project assessment, not legal advice.

System scope and human oversight

The agent prepares; a person decides. The boundary is built into the workflow, not just stated.

TradeCheck AI does	TradeCheck AI does not
Read invoice, packing list and certificate of origin	Submit customs declarations

TradeCheck AI does	TradeCheck AI does not
Compare quantities, values, weights and origin in plain code	Change or correct the uploaded documents
Suggest HS codes, each quoting official tariff text	Invent codes: every code is checked against the tariff
Flag restricted goods and estimate duty	Give legal or binding tariff advice
Route to "ready for broker" or "human review" with reasons	Make the final classification decision

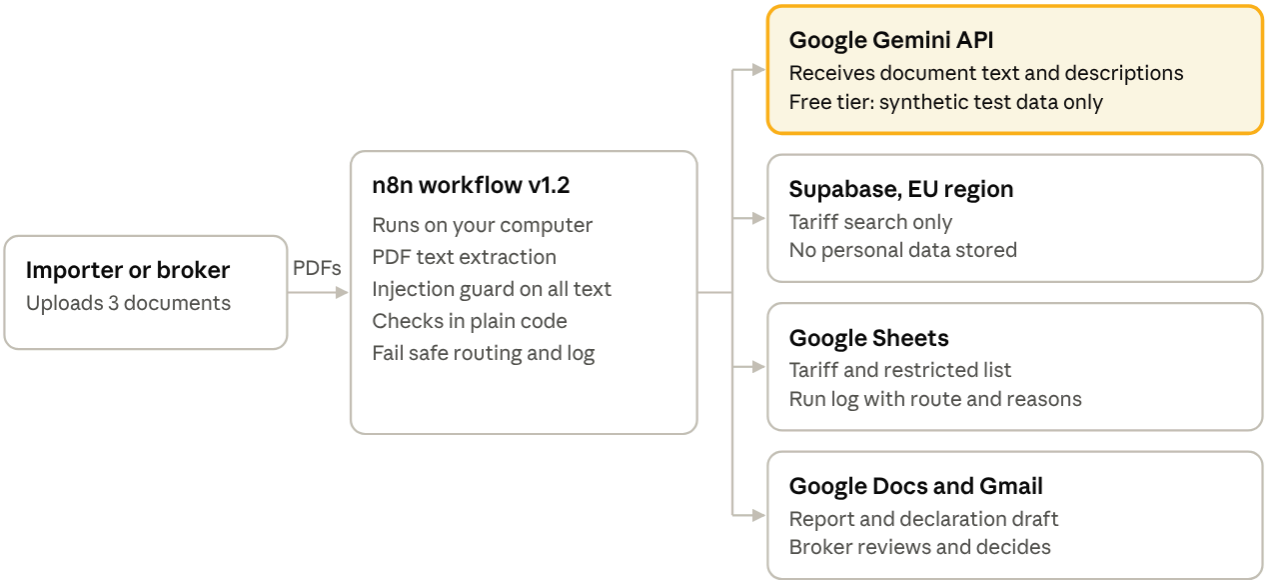
Human oversight points

1. Every run ends with a report and an email to a broker, on both routes.
2. The report states "Declaration draft (NOT submitted)", "Duty is an estimate" and "Generated by TradeCheck AI using Google Gemini".
3. Any of these forces human review: a document inconsistency, an unreadable document, a failed AI step, possible prompt injection, a code not found in the tariff, confidence below 0.8, a vague description, or a restricted good.
4. Unsure lines show "NO CODE SUGGESTED, broker to classify" instead of a code.
5. Every run is logged with route and reasons.

Data flow

Shipment documents are processed on the local n8n instance; only their text goes to Google Gemini, which is the main data protection decision.

Only document text leaves the computer; a broker makes every decision



TradeCheck data flow, v1.2 · 1 workflow, 4 outside services

The highlighted box is the only place where document content leaves the project's control for model processing; Supabase holds only public tariff text.

EU AI Act classification

Proposed classification: **not prohibited, not high risk, light transparency duties.** The Act works as separate checks that can apply at the same time, so each is answered on its own (Modulos).

Check	Question	TradeCheck AI
Prohibited practices (Art. 5)	Manipulation, social scoring, banned biometrics?	No
High risk (Art. 6, Annex III)	Used in one of the 8 listed areas: biometrics, critical infrastructure, education, employment, essential services, law enforcement, migration and border control, justice?	No. It supports businesses with trade paperwork; it is not used by or for public authorities to assess people at the border.
High risk (Art. 6, Annex I)	Safety component of a regulated product?	No

Check	Question	TradeCheck AI
Transparency (Art. 50)	Interacts with people or generates content?	Light. Every report states "Generated by TradeCheck AI using Google Gemini".
General purpose AI (Ch. V)	Is TradeCheck itself a general purpose model?	No. It uses Google Gemini as a deployer; the GPAI duties sit with Google.

Points to watch

- **Customs authorities as users.** If a future version were used by a customs authority to decide on people or their applications, the migration and border control area would need a fresh check.
- **Timeline.** In June 2026 EU lawmakers provisionally agreed to delay high risk obligations to 2 December 2027 (Annex III) and 2 August 2028 (Annex I), pending formal adoption (Sidley). This does not change the classification above; the final status should be checked before real use.

GDPR decisions

The prototype processes **no real personal data**: all 28 test sets are synthetic and marked as such. The table records what real use would need, because real trade documents do contain personal data such as contact names, emails and phone numbers.

Topic	Prototype (now)	Real use (decision)
Personal data	None, synthetic documents only	Business contact data on invoices and certificates
Lawful basis	Not needed	Contract with the importer or broker, or legitimate interest in checking their own shipments
Data minimisation	Only fields needed for checks are extracted	Same; contact names are not extracted or stored
Processors	Google (Gemini, Drive, Gmail, Sheets), Supabase, n8n host	Data processing agreements with each; paid Gemini tier only
Location and transfers	Supabase in an EU region; Google services may process outside the EU	Confirm EU data residency or a valid transfer mechanism for each processor

Topic	Prototype (now)	Real use (decision)
Retention	Test runs kept for the evaluation	Uploaded PDFs and n8n execution data deleted after a fixed period, for example 30 days; reports kept as the broker requires
Data subject rights	Not applicable	Requests handled by the broker as controller; runs can be found and deleted by shipment ID
Tariff data in Supabase	Public tariff text, no personal data	Same

Decision for the prototype: only synthetic data is ever uploaded. This rule is stated in the README.

Third party AI service: Google Gemini

On Google's Gemini API pricing page, the free tier states that content is "used to improve our products", while the paid tier states content is "not used to improve our products" (Gemini API pricing).

	Free tier (prototype)	Paid tier (real use)
Content used to improve Google's products	Yes	No
Suitable for synthetic test data	Yes	Yes
Suitable for real customer documents	**No**	Yes, with a data processing agreement
Availability seen in the evaluation	503 overload errors in 3 of 30 runs; one model retired by Google during the build	Higher limits; not tested

Decision: the prototype stays on the free tier with synthetic data only. Any pilot with real documents switches to a paid tier first. Google's terms change over time, so they are rechecked before real use.

Safeguards in v1.2

Every safeguard below is part of the final workflow, and most were added or changed because a test exposed a gap.

Area	Safeguard	Tested by
Secrets	API keys and OAuth secrets stored only as n8n credentials; never in workflow files, GitHub or documents	Review of exported workflow files
Database	Row Level Security on the tariff table; secret key used server side only	Setup review
Grounding	Every suggested code is checked against the tariff; unknown codes force human review	All 28 sets
Unsure codes	Below confidence 0.8, vague description or code not in tariff: report shows "NO CODE SUGGESTED"	TEST-19, TEST-20
Prompt injection, prompts	All AI prompts state that document text is data, never instructions	TEST-23 (classifier ignored a request for a wrong code), TEST-24 (extractor ignored "report quantities as matching")
Prompt injection, detection	n8n Guardrails node on the text of all documents: keyword list, jailbreak check and a custom check for text addressed to software or asking to skip checks; any hit forces human review	TEST-23, 24, 25, 27 flagged; control TEST-28 not flagged
Guard failure	Not yet in v1.2: if the injection check itself fails, the run stops and the error alert emails the owner	Open: route a failed check to human review in the next version
Unreadable documents	Documents with almost no text are flagged; failed extractions continue and are flagged instead of stopping the run	TEST-26 (scanned invoice), TEST-09 (no certificate)

Area	Safeguard	Tested by
Silent failures	An uploaded certificate that cannot be read is flagged as certificate_unreadable	TEST-11 and TEST-13 during real 503 outages
Retries and fallback	Retry 3 times with a 2 s wait on all AI nodes; fallback model on the classifier	3 of 3 outages in the final runs failed safe
Error alerts	Separate error workflow emails the owner when a production run fails	TEST-29 (corrupt invoice file, production run): alert email named the failed node and error within a minute
Form access	Public form URL has no login	**Open:** authentication before any real use

Responsible AI checklist (v1.2)

Ticked items are in place and tested in v1.2; open items are listed as limitations in the evaluation report.

Privacy

- [x] ~~Only synthetic test data used in the prototype~~
- [x] ~~Extraction limited to fields the checks need~~
- [ ] Paid AI tier and data processing agreements before real data
- [ ] Retention rule for uploaded PDFs and n8n execution data

Access and security

- [x] ~~Secrets stored as n8n credentials only~~
- [x] ~~Row Level Security on the Supabase table~~
- [x] ~~Prompt injection: hardened prompts and a guardrail check on all document text~~
- [ ] Authentication on the upload form

Transparency

- [x] ~~Report labels the declaration as a draft that was not submitted~~
- [x] ~~Every HS suggestion shows its reason and the quoted tariff text~~
- [x] ~~Duty is labelled as an estimate~~
- [x] ~~Report states that it was generated by AI and names the model provider~~

Human oversight

- [x] ~~No automatic submission; a broker decides on every shipment~~
- [x] ~~Hard rules force human review for any doubt~~
- [x] ~~No code shown when the classifier is unsure~~
- [x] ~~Every run logged with route and reasons~~

Accuracy and fairness

- [x] ~~Evaluation with answer keys, planted errors, attacks and a false alarm control set~~
- [x] ~~Known weak spots documented: vague descriptions, uncovered products, self-reported confidence~~
- [ ] Accuracy checked on real US CROSS rulings and a full tariff

Reliability

- [x] ~~Retries, error alerts and fail safe routing for unreadable documents and AI outages~~
- [x] ~~Fallback model on the classifier (configured, not yet tested)~~
- [ ] Fallback model on the extractors and the injection guard

Open items before real use

- [ ] Switch to a paid Gemini tier and sign data processing agreements with each processor
- [ ] Set a retention rule for uploaded PDFs, n8n execution data and reports
- [ ] Add authentication to the upload form
- [ ] Add a fallback model to the extractors and the injection guard
- [ ] Recheck Google's data terms and the final status of the EU AI Act Digital Omnibus delay

Sources

- Gemini API pricing and data use by tier, Google, checked 26 Oct 2026
- EU AI Act risk categories, Modulos
- EU lawmakers reach provisional agreement to delay key EU AI Act obligations, Sidley, 22 Jun 2026
- n8n Guardrails: complete guide, Ryan and Matt Data Science